

"Salla Store" E-commerce Project.

Case Study:

Part One: Organizational Controls

1.1. Control (5.1): Policies for Information Security

Lead Implementor's Responsibility:

Lead the development and implementation of a comprehensive information security policy lifecycle within "Salla Store."

Detailed Tasks:

- **Policy Initiation and Drafting:**
 - Form a cross-functional working group to develop initial drafts of information security policies, focusing on user behavior, data handling, system access, and incident management.
 - Ensure all policies strictly comply with relevant consumer protection laws and electronic transaction regulations applicable in "Salla Store's" operating regions.
- **Review and Approval:**
 - Coordinate the review process with key stakeholders, including legal and compliance teams.
 - Present final policy drafts to senior management (e.g., CEO or Head of Information Security) for formal approval.
- **Communication and Implementation:**
 - Develop an effective communication plan to disseminate policies to all affected personnel.
 - Ensure mechanisms are in place for employees to confirm receipt and understanding of policies (e.g., mandatory acknowledgment receipts or policy awareness training sessions).
- **Periodic Review and Updates:**

- Establish a defined schedule for periodic reviews of all policies to reflect changes in the threat landscape, technological advancements, and business operations.
- Document all reviews and amendments, along with the rationale for these changes.

Required Evidence to Provide (for Auditor's Review):

- **Approved Policy Documents:** Formally endorsed policy documents (e.g., PDF files or controlled internal documents) bearing explicit senior management approval.
- **Communication Records:** Comprehensive documentation demonstrating effective policy dissemination to all employees (e.g., email distribution lists, notifications via employee management system, acknowledgment receipts, training attendance records).
- **Policy Review Logs:** Meticulously maintained schedules detailing review dates for each policy, identifying reviewers, and documenting modifications with their rationale.

1.2. Control (5.2): Information Security Roles and Responsibilities

Lead Implementor's Responsibility:

Clearly define and formally assign specific information security roles and responsibilities across all organizational levels.

Detailed Tasks:

- **Appoint Leadership Roles:**
 - Ensure a dedicated Information Security Officer (CISO or Information Security Manager) is appointed to lead the ISMS.
- **Define Departmental Responsibilities:**
 - In collaboration with department heads, granularly define information security responsibilities for each team (e.g., Development Team, Operations Team, Customer Service Team, Senior Management).
 - Ensure each team understands its contribution to the overall security posture.

- **Develop Job Descriptions and Reporting Lines:**
 - Incorporate specific information security tasks and responsibilities into job descriptions.
 - Establish clear information security reporting lines.
- **Training and Awareness:**
 - Ensure all personnel are adequately trained and aware of their security obligations.
 - Collect signatures or acknowledgments from employees confirming their reading, understanding, and acceptance of their information security policies and responsibilities.

Required Evidence to Provide:

- **Role Descriptions:** Detailed documents outlining specific information security tasks and responsibilities for each job role.
- **Organizational Charts:** Visual representations explicitly depicting reporting relationships and allocated security responsibilities within "Salla Store's" structure.
- **Acknowledgement Forms:** Signed documents from employees confirming their understanding and acceptance of information security policies and responsibilities.
- **Training Records:** Comprehensive records of employee attendance and completion of security awareness training sessions, highlighting their understanding of assigned security responsibilities.

1.3. Control (5.3): Segregation of Duties

Lead Implementor's Responsibility:

Implement the principle of segregation of duties to mitigate the risk of fraud, errors, or unauthorized actions.

Detailed Tasks:

- **Identify Conflicts of Interest:**
 - Analyze job roles and processes to identify any potential conflicts of interest where a single individual could have complete control over a critical process or access to sensitive assets.

- **Design Workflows:**
 - Redesign workflows to incorporate segregation, ensuring incompatible responsibilities are distributed among different individuals or teams (e.g., separation of software code developer and code deployer, separation of customer order processors from direct administrative access to sensitive credit card databases).
- **Implement Compensating Controls:**
 - Where complete segregation is impractical, design and implement robust compensating controls (e.g., the "Four-eyes principle" requiring approval from a second independent party, or detailed, regularly reviewed audit logs).
- **Regular Review:**
 - Conduct regular reviews of access rights and audit trails to ensure compliance with the segregation of duties policy.

Required Evidence to Provide:

- **Segregation of Duties Policy:** A formal document outlining the guiding principles and specific requirements for segregation of duties.
- **Access Control Logs:** Systemic, tamper-proof records detailing who has accessed which system or data, and who has performed specific actions.
- **Audit Reports:** Internal or external reports providing independent verification of the segregation of duties policy's implementation, highlighting identified violations or weaknesses.
- **Roles and Permissions Matrix:** A comprehensive table clearly mapping organizational roles to specific permissions and access rights granted within various systems, illustrating adherence to segregation principles.

1.4. Control (5.4): Management Responsibilities

Lead Implementor's Responsibility:

Ensure active support and championship of information security from senior management across the entire organization.

Detailed Tasks:

- **Resource Allocation:**

- Work with senior management to ensure the allocation of necessary financial and human resources for information security initiatives (e.g., security tool procurement, specialized training programs, recruitment of cybersecurity professionals).

- **Oversight and Review:**

- Coordinate senior management's active participation in periodic information security reviews to assess ISMS performance, review security metrics, and make informed decisions.

- **Issue Resolution:**

- Establish a mechanism for senior management to promptly address and resolve escalated security issues, demonstrating a proactive approach to risk management.

- **Promote Security Culture:**

- Support senior management in leading by example to foster a robust security awareness culture among all employees, emphasizing individual accountability in protecting information assets.

Required Evidence to Provide:

- **Management Meeting Minutes:** Official minutes documenting discussions held during senior management meetings regarding information security, including budget allocations, resource approvals, and ISMS performance reviews.
- **Resource Allocation Records:** Documentation proving dedicated allocation of financial and human resources to information security activities (e.g., invoices for security software licenses, employment contracts for security personnel, training budgets).
- **ISMS Performance Reports:** Regular, comprehensive reports presented to senior management summarizing the current security posture, detailing security incidents, reporting on compliance status, and evaluating the effectiveness of implemented controls.
- **Security Policy Statement Document:** A formal statement issued and endorsed by senior management, unequivocally affirming their commitment to information security and its critical importance.

Part Two: Data Protection Controls

2.1. Control (8.10): Information Deletion

Lead Implementor's Responsibility:

Establish and enforce clear policies and procedures for the secure and irreversible deletion of data.

Detailed Tasks:

- **Develop Deletion Policy:**
 - Draft a formal, documented policy specifying criteria for data deletion (e.g., retention periods, end of purpose), roles responsible for deletion, and approved secure methods for various data types and storage media.
- **Define Deletion Procedures:**
 - Establish detailed procedures for identifying data no longer required, selecting appropriate secure deletion methods based on data sensitivity and storage medium (e.g., data overwriting for hard drives, secure deletion commands for database records, physical destruction for deprecated physical media).
- **Execution and Verification:**
 - Oversee the execution of deletion operations.
 - Create a process for verifying successful and complete deletion, using data recovery verification tools or post-deletion integrity checks.
- **Documentation and Audit:**
 - Ensure detailed, auditable records are maintained for each deletion operation.

Required Evidence to Provide:

- **Deletion Policies:** A formal, documented policy specifying the criteria for data deletion, responsible roles, and approved secure methods.
- **Logs of Deletion Activities:** Detailed, auditable records documenting each deletion operation.

- **Verification Records:** Reports or test results confirming the success and completeness of data deletion.

2.2. Control (8.11): Data Masking

Lead Implementor's Responsibility:

Implement data masking or data anonymization techniques to protect sensitive information in non-production environments.

Detailed Tasks:

- **Develop Data Masking Policy:**
 - Draft a clear document outlining the policy for data masking, specifying when and why it is applied, the types of data that must be masked, permissible masking techniques, and the mandatory non-production environments.
- **Identify Sensitive Fields and Techniques:**
 - Identify sensitive data fields in production environments.
 - Select appropriate masking techniques (e.g., substitution, shuffling, encryption with a one-way hash, nulling) that maintain data format and realism for testing purposes.
- **Implementation and Verification:**
 - Oversee the application of masking techniques using specialized tools or custom scripts.
 - Ensure the effectiveness of masking is verified through quality assurance and security testing teams.

Required Evidence to Provide:

- **Data Masking Policies:** A clear document outlining the policy for data masking, specifying its application, data types to be masked, permissible techniques, and mandatory non-production environments.
- **Implementation Reports:** Documents detailing the execution of data masking processes, including specifications of tools/scripts used, datasets masked, and configuration parameters.

- **Testing Logs:** Records from quality assurance and security testing confirming that sensitive data in non-production environments has been correctly masked and does not expose real, identifiable information.

2.3. Control (8.12): Data Leakage Prevention (DLP)

Lead Implementor's Responsibility:

Implement robust Data Leakage Prevention (DLP) solutions to mitigate the risk of unauthorized data exfiltration.

Detailed Tasks:

- **DLP Tool Deployment:**
 - Strategically plan and deploy DLP tools across critical egress points of "Salla Store's" network and on employee endpoints.
- **Define Data Types and Rules:**
 - Define sensitive data types (e.g., credit card numbers, national ID numbers, customer email addresses) and establish associated rules for DLP tools.
- **Monitoring and Response:**
 - Establish a process for continuous monitoring of data flows and detection of policy violations.
 - Define automated or manual response actions upon policy violation detection (e.g., block, quarantine, alert).
- **Integration and Analysis:**
 - Ensure DLP tools are integrated into "Salla Store's" IT infrastructure to monitor data movement across the network and on individual employee computers.
 - Regularly review and analyze monitoring logs for compliance and continuous improvement.

Required Evidence to Provide:

- **DLP Tool Configurations:** Comprehensive documentation, including screenshots or detailed configuration files, illustrating precise settings and rules applied to DLP tools.

- **Incident Reports:** Formal reports documenting detected data leakage attempts or policy violations by the DLP system.
- **Monitoring Logs:** Regular, detailed logs generated by DLP tools, providing insights into data movement, suspicious activities, and executed alerts or blocking actions.